COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.4 · Cryptographic Attacks

Mestre CyberSec · **Lesson 2.4 — Cryptographic Attacks** (9:31) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Downgrade attack: convence as partes a usar protocolo FRACA (SSL strip: HTTPS→HTTP); hash collision (2 textos, mesmo hash — MD5 morreu por collision); brute force da chave. Defesa: HSTS (browser NUNCA aceita downgrade pra HTTP), patch crypto, algoritmo atual (TLS 1.3).

💡 Key Exam Highlights & Critical Concepts

- Downgrade: convence pra usar versão FRACA (SSL stripping)
- HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip
- Collision MD5/SHA-1: dois textos, mesmo hash — abandonados

🎯 Exam Tips & Typical CompTIA Scenarios

- 'forces a connection to a weaker protocol' = downgrade attack
- 'prevents downgrade to HTTP' = HSTS

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.4 — Cryptographic Attacks)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Downgrade Attack (N/A)

An attack that forces two parties to negotiate an older, weaker protocol or cipher suite instead of the strongest mutually supported option.

⚠️ ***Exam Trap:*** *Se a questão disser 'forces a connection to a weaker protocol', marque downgrade attack; não confunda com SSL stripping, que é uma forma específica de downgrade de HTTPS para HTTP.*

• SSL Stripping (N/A)

A downgrade attack where an attacker intercepts HTTPS traffic and relays it to the victim as HTTP, stripping TLS encryption.

⚠️ ***Exam Trap:*** *Associe SSL stripping a downgrade HTTPS→HTTP; HSTS é a mitigação porque o navegador se lembra de exigir HTTPS.*

• HTTP Strict Transport Security (HSTS)

A web security policy that instructs browsers to only connect to a site over HTTPS and never allow downgrade to HTTP.

⚠️ ***Exam Trap:*** *Se a questão pergunta o que impede downgrade para HTTP/SSL strip, a resposta é HSTS.*

• Hash Collision (N/A)

A situation where two different inputs produce the same hash value, breaking integrity and digital signature assurances.

⚠️ ***Exam Trap:*** *Duas mensagens diferentes com o mesmo hash = colisão. MD5 e SHA-1 são abandonados justamente por colisões.*

• MD5 (Message Digest 5)

A deprecated 128-bit hash algorithm that is cryptographically broken due to practical collision attacks.

⚠️ ***Exam Trap:*** *Se a questão citar MD5, geralmente é para indicar hash fraco/colisão; prefira SHA-256/SHA-3.*

• **SHA-1 (Secure Hash Algorithm 1)**

A deprecated 160-bit hash algorithm vulnerable to collision attacks and no longer approved for secure use.

⚠️ ***Exam Trap:*** *SHA-1 também sofreu colisão; CompTIA espera que você saiba que MD5 e SHA-1 não devem ser usados para integridade/assinaturas.*

• **Brute Force Attack (N/A)**

An attack that systematically tries every possible key, password, or combination until the correct one is found.

⚠️ ***Exam Trap:*** *Se a questão mencionar tentar todas as combinações/chaves, é brute force; defenda com chaves longas, algoritmos fortes e limitação de tentativas.*

• **Transport Layer Security 1.3 (TLS 1.3)**

The current version of TLS that removes legacy weak algorithms and includes downgrade protection for secure negotiation.

⚠️ ***Exam Trap:*** *TLS 1.3 é a resposta atual para evitar downgrade; SSL e TLS antigos (1.0/1.1) são fracos/obsoletos.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Birthday Attack & Hash Collisions

🏠 **Real-World Analogy:** In a room of just 23 people, there is a greater than 50% statistical probability that two people share the exact same birthday. The reason is that you are not searching for someone matching YOUR specific birthday; you are searching for ANY matching pair. In a Birthday Attack, an attacker creates two radically different files (a legitimate lease and a fraudulent property transfer) and makes invisible formatting tweaks until both generate the identical cryptographic hash output. The attacker gets the victim to digitally sign the benign file, but applies that valid digital signature to the fraudulent document.

🔍 **Root Cause & Background:** The birthday paradox drastically diminishes the mathematical trials needed to find two distinct inputs yielding identical hash outputs (reducing complexity from 2^n to 2^(n/2)). Weak hash algorithms with short digest lengths (MD5 128-bit, SHA-1 160-bit) make computational collisions achievable.

🛡️ **GRC Auditor Perspective:** Strictly deprecate vulnerable hashing algorithms (MD5 and SHA-1) across enterprise standards to meet PCI-DSS and FIPS 140-3 mandates; standardize exclusively on SHA-256/SHA-512 (SHA-2) or SHA-3.

⚠️ **How CompTIA Tests This:** Trigger: 'attacker finds two distinct inputs resulting in the exact same cryptographic hash value' -> Birthday Attack / Hash Collision. Classic exam examples: MD5 and SHA-1.

📌 Downgrade Attack & SSL Stripping

🏠 **Real-World Analogy:** A Downgrade Attack is like arriving at a consulate prepared to speak in modern encrypted code, but a dishonest guard at the gate insists: 'Our modern cipher is offline; you must converse in an obsolete 16th-century dialect', allowing eavesdroppers to easily decipher your conversation. SSL Stripping is an on-path attacker intercepting an encrypted padlock envelope (HTTPS), discarding the lock, and substituting a transparent clear plastic sleeve (HTTP) before forwarding it to the user, who mistakenly browses without encryption.

🔍 **Root Cause & Background:** Backward compatibility leads web servers to permit legacy, broken protocol handshakes (SSLv3, TLS 1.0). In SSL Stripping, an on-path adversary intercepts unencrypted initial HTTP GET requests and withholds the 301/302 HTTPS redirect, keeping the client communicating over unencrypted plaintext.

🛡️ **GRC Auditor Perspective:** Disable obsolete cipher suites and protocols on all load balancers (purging SSLv3, TLS 1.0, TLS 1.1); mandate HTTP Strict Transport Security (HSTS) with the `preload` directive to instruct client browsers never to issue cleartext HTTP requests.

⚠️ **How CompTIA Tests This:** Trigger: 'attacker forces connection to negotiate a weaker, outdated protocol version' -> Downgrade Attack. Trigger: 'transparent conversion of HTTPS requests into unencrypted HTTP' -> SSL Stripping. Definite defense: HSTS.

📌 Replay Attacks & Nonce/Timestamp Defenses

🏠 **Real-World Analogy:** A Replay Attack is like an intruder tape-recording an executive unlocking a voice-activated vault door. Later that night, the burglar plays back the exact audio recording. The lock opens because it only evaluates the raw audio signal. A Nonce (number used once) stops this by requiring a unique challenge: the vault displays 'Combine your passphrase with one-time code 7392'. Because code 7392 is only valid for 3 seconds and never repeated, the recorded audio playback is promptly rejected as stale.

🔍 **Root Cause & Background:** Authentication exchanges lacking time-bound ephemeral entropy transmit reusable tokens or hashes. Threat actors capture the network transmission and retransmit the exact payload to impersonate the client without needing to crack the secret.

🛡️ **GRC Auditor Perspective:** Deprecate legacy authentication protocols vulnerable to replay (NTLM) in favor of Kerberos with strict Kerberos timestamp skew tolerances (NTP synchronization); enforce session nonces and ephemeral challenges in API protocols.

⚠️ **How CompTIA Tests This:** Trigger: 'attacker sniffs valid session authentication data and resends the packets to authenticate' -> Replay Attack. Primary defenses: Cryptographic Nonces and Timestamps.

📌 Known Plaintext vs. Ciphertext-Only Attacks

🏠 **Real-World Analogy:** Ciphertext-Only is a cryptanalyst finding a locked diary written in an unrecognizable alien code with zero clues regarding its content or language. Known Plaintext is when the analyst intercepts the encrypted file but already knows with absolute certainty that the first 50 characters represent a standard formal header (such as 'CONFIDENTIAL - EXECUTIVE MEMO:'). By matching the known plaintext header against the corresponding encrypted ciphertext block, the adversary mathematically deduces the encryption key.

🔍 **Root Cause & Background:** Improper encryption modes (such as AES in Electronic Codebook / ECB mode) encrypt identical plaintext blocks into identical ciphertext blocks. When an attacker possesses predictable structural headers (file headers, standard salutations), they reverse-engineer key parameters.

🛡️ **GRC Auditor Perspective:** Ban deterministic cipher modes (such as ECB) across secure coding standards; mandate authenticated modes (AES-GCM) utilizing cryptographically random, non-repeating Initialization Vectors (IV).

⚠️ **How CompTIA Tests This:** Trigger: 'attacker possesses both encrypted ciphertext and the corresponding original plaintext for known message fragments' -> Known Plaintext Attack. If possessing solely raw encrypted ciphertext: Ciphertext-Only Attack.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Attacker produces two completely distinct plaintexts that resolve to the exact same cryptographic hash digest	**Hash Collision / Birthday Attack**
Attacker forces client and server to discard modern secure algorithms and fall back to a vulnerable legacy protocol	**Downgrade Attack**
Security response header directing browsers to communicate exclusively over encrypted HTTPS connections	**HSTS (HTTP Strict Transport Security)**
Attacker intercepts valid authentication packets and replays them to impersonate a legitimate user without cracking credentials	**Replay Attack**
One-time random numeric value incorporated into cryptographic handshakes to guarantee freshness and prevent replay	**Nonce (Number Used Once)**
Cryptanalyst utilizes known snippets of unencrypted plaintext alongside matching encrypted ciphertext to discover keys	**Known Plaintext Attack**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A user connects to a coffee shop Wi-Fi network and enters http://portal.example.com. An attacker intercepts the initial request, keeps the browser communicating over HTTP, and silently proxies requests to the real HTTPS site while logging credentials. Which attack is being described?

A) SSL stripping/downgrade attack

B) Hash collision attack

C) Brute-force key recovery

D) Certificate pinning bypass

QUESTION 2 · EXAM SCENARIO

After an SSL stripping incident on public networks, a company wants browsers to never silently downgrade from HTTPS to HTTP for its domain and all subdomains. Which deployment should the security engineer implement?

A) DNSSEC with NSEC3 validation

B) HSTS policy with includeSubDomains and preload

C) SHA-256 code signing for all applications

D) TLS 1.3 with perfect forward secrecy only

QUESTION 3 · EXAM SCENARIO

A security researcher submits two different PDF files that produce the same MD5 digest. A malicious insider plans to replace a benign contract with a fraudulent one while keeping the published MD5 checksum unchanged. Which cryptographic attack does this illustrate?

A) Downgrade attack

B) Brute-force key recovery

C) Hash collision attack

D) Replay attack

QUESTION 4 · EXAM SCENARIO

A legacy internal application signs software updates with SHA-1. The vendor warns that an attacker could create a malicious update with the same SHA-1 value as a legitimate update. Which risk is the vendor describing?

A) Collision resistance failure

B) Cipher suite downgrade

C) Key exhaustion

D) HSTS bypass

QUESTION 5 · EXAM SCENARIO

An attacker captures an encrypted archive protected with a 56-bit DES key. The attacker systematically tries every possible key until the archive opens. Which type of attack is this?

A) Hash collision

B) SSL stripping

C) Downgrade attack

D) Brute-force attack

QUESTION 6 · EXAM SCENARIO

During a TLS handshake, a man-in-the-middle modifies the client hello and server hello so the connection uses TLS 1.0 instead of TLS 1.3. Which attack has occurred?

A) Hash collision attack

B) Downgrade attack

C) Brute-force key search

D) Cross-site request forgery

QUESTION 7 · EXAM SCENARIO

A company enables HSTS for app.example.com but does not set includeSubDomains. What residual risk remains?

A) MD5 certificates on the main domain become collision-prone.

B) TLS 1.3 sessions will automatically fall back to SHA-1.

C) A subdomain such as login.example.com can still be downgraded on a user's first visit.

D) Brute-force attacks against AES-256 become feasible.

QUESTION 8 · EXAM SCENARIO

A web server supports TLS 1.0, TLS 1.1, TLS 1.2, and TLS 1.3. Administrators want to reduce the chance that clients negotiate obsolete protocols during a man-in-the-middle handshake. Which server-side change is most appropriate?

A) Replace the server's SHA-256 certificate signature with MD5.

B) Enable HSTS only for HTTP on port 80.

C) Increase the RSA key size from 2048 to 3072 bits only.

D) Disable TLS 1.0 and TLS 1.1, and require TLS 1.2 or TLS 1.3.

QUESTION 9 · EXAM SCENARIO

A software build system verifies release binaries by comparing SHA-1 hashes. Security leadership wants to protect against an adversary crafting a malicious binary that has the same hash as the approved binary. Which action should be taken first?

A) Migrate release integrity checks to SHA-256 or SHA-3.

B) Enforce HSTS preload for the build server.

C) Reduce TLS cipher suites to 3DES.

D) Store the SHA-1 hashes in a public DNS TXT record.

QUESTION 10 · EXAM SCENARIO

An organization uses an embedded device that encrypts telemetry with a 64-bit symmetric key. A penetration tester recovers the key by trying all possible values offline. Which remediation most directly reduces this brute-force risk?

A) Enable HSTS on the device management web interface.

B) Replace the algorithm/key length with AES-256.

C) Switch message integrity from SHA-256 to MD5.

D) Require users to change passwords every 30 days.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — SSL stripping/downgrade attack

SSL stripping is a downgrade attack where the attacker prevents the browser from upgrading to HTTPS and relays traffic to the real site. Hash collisions involve two inputs with the same digest, brute force guesses keys, and certificate pinning bypass is a different TLS interception concern. HSTS is the primary defense against SSL stripping.

Question 2: Option B — HSTS policy with includeSubDomains and preload

HSTS instructs the browser to always use HTTPS for a host and to refuse user or attacker attempts to downgrade to HTTP. The includeSubDomains and preload directives extend that protection to subdomains and help before the first visit. DNSSEC protects DNS integrity, code signing protects software, and TLS 1.3 strengthens the handshake but does not by itself stop an initial HTTP URL from being stripped.

Question 3: Option C — Hash collision attack

A hash collision occurs when two different inputs produce the same hash value. MD5 is no longer considered collision-resistant, so an attacker can substitute a fraudulent file while preserving the checksum. Downgrade and brute-force attacks target protocols or keys, and a replay attack reuses captured valid data.

Question 4: Option A — Collision resistance failure

SHA-1 has known collision weaknesses, meaning an attacker may generate two different updates with the same digest. This breaks integrity verification based on SHA-1. A cipher suite downgrade targets protocol negotiation, key exhaustion is not the core issue, and HSTS relates to web transport downgrade prevention.

Question 5: Option D — Brute-force attack

Trying every possible key until the correct one is found is a brute-force attack. DES's 56-bit key space is small enough to be exhausted with modern hardware. Hash collisions target digests, SSL stripping downgrades HTTP, and a downgrade attack weakens protocol negotiation.

Question 6: Option B — Downgrade attack

A downgrade attack forces two parties to negotiate an older, weaker protocol or cipher than they would otherwise support. Here the MITM manipulates the handshake to select TLS 1.0 instead of TLS 1.3. Hash collisions target integrity digests, brute force guesses keys, and CSRF is a web application attack.

Question 7: Option C — A subdomain such as login.example.com can still be downgraded on a user's first visit.

Without includeSubDomains, the HSTS policy applies only to app.example.com and not to its subdomains. An attacker may still strip HTTPS on an unprotected subdomain, especially before HSTS is known. MD5 certificate risk, TLS 1.3 fallback to SHA-1, and brute-forcing AES-256 are not accurate consequences of this HSTS configuration.

Question 8: Option D — Disable TLS 1.0 and TLS 1.1, and require TLS 1.2 or TLS 1.3.

Removing TLS 1.0 and TLS 1.1 from the server's supported protocols prevents clients and attackers from negotiating those obsolete versions. Requiring TLS 1.2 or TLS 1.3, ideally only TLS 1.3, strengthens the handshake. MD5 weakens signatures, HSTS on port 80 is misconfigured, and a larger RSA key does not stop protocol downgrade.

Question 9: Option A — Migrate release integrity checks to SHA-256 or SHA-3.

SHA-1 is considered weak for collision resistance, so integrity verification should move to a modern hash such as SHA-256 or SHA-3. HSTS and DNS TXT records do not fix hash collision risk, and using 3DES weakens transport security.

Question 10: Option B — Replace the algorithm/key length with AES-256.

Brute-force resistance depends on the key space; moving from a 64-bit key to AES-256 greatly increases the number of possible keys and makes exhaustive search infeasible. HSTS protects web transport, MD5 weakens integrity, and password expiration does not address the symmetric telemetry key.